

REPORT DI AUDIT · ESEMPIO ANONIMIZZATO

Audit di sicurezza e documentale

Applicazione web (caso reale anonimizzato)

Esaminato **Provato** **Ignoto**

OGGETTO	Repository del cliente (esempio)
VERSIONE ESAMINATA	commit esempio0001
MODALITÀ	rapido · solo analisi statica e documentale
DATA	2026-10-30
PREPARATO DA	Claude con appsec-sentinel
CLASSIFICAZIONE	ESEMPIO · RISERVATO

Documento riservato. Non costituisce certificazione né parere legale.

Indice

Sintesi per il proprietario 2
Quadro dei finding 3
Dettaglio dei finding 4
Audit documentale 9
Copertura e limiti 10
Matrici di copertura 11
Piano di intervento proposto 12

1 Sintesi per il proprietario

- Cinque finding confermati da codice o configurazione; nessun test dinamico, quindi nessuno «riprodotto».
- Priorità alte: un endpoint di seed senza autenticazione che crea utenti con password nota, e un framework con advisory noti, fra cui bypass del middleware.
- L'audit documentale mostra dichiarazioni di sicurezza non sostenute dal codice: l'MFA è descritta nel middleware ma applicata solo dal browser.
- Tre documenti sovrapposti sullo stato di conformità, un rapporto di test senza autore né metodo, 37 file di lavoro nella radice del repository.



5 finding in totale. Stato: 5 confermato da codice o configurazione.

DA FARE PER PRIMO

APP-002 · Endpoint di arricchimento demo esente da autenticazione crea utenti con password fissa. Bloccare /api/internal/ dal reverse proxy; verificare se esistono account demo in produzione e cambiarne le password

APP-005 · Next.js 16.1.7 e Auth.js beta con advisory noti, inclusi bypass del middleware su cui poggia l'autenticazione. Aggiungere controlli di sessione e ruolo anche nei gestori delle route, non solo nel middleware

2 Quadro dei finding

ID	SEVERITÀ	TITOLO	STATO
APP-002	ALTA	Endpoint di arricchimento demo esente da autenticazione crea utenti con password fissa	confermato da codice o configurazione
APP-005	ALTA	Next.js 16.1.7 e Auth.js beta con advisory noti, inclusi bypass del middleware su cui poggia l'autenticazione	confermato da codice o configurazione
APP-001	MEDIA	File di configurazione staging con valori reali dichiarati, tracciato in Git	confermato da codice o configurazione
APP-003	MEDIA	Route di debug e seed raggiungibili da qualsiasi utente autenticato, con effetti di stato via GET	confermato da codice o configurazione
APP-004	MEDIA	Accettazione preventivo senza controllo di proprietà: risposta con password temporanea e dati del contatto	confermato da codice o configurazione

Gli stati dichiarati sono quelli effettivamente raggiunti: «confermato da codice o configurazione» non equivale a «riprodotto dinamicamente».

3 Dettaglio dei finding

APP-002	Endpoint di arricchimento demo esente da autenticazione crea utenti con password fissa	ALTA
STATO E CONFIDENZA	confermato da codice o configurazione · confidenza media	
RIFERIMENTI	CWE-306, CWE-798 · ASVS v5.0.0 (controllo di accesso, credenziali predefinite); WSTG-ATHN-02; NIST SP 800-53 AC-3, IA-5	
PROVA	Il middleware elenca /api/internal/demo-seed tra i percorsi pubblici. Il gestore POST non ha controlli di sessione, ruolo, token o ambiente; calcola l'hash di una password fissa scritta nel codice e fa upsert di utenti RESPONSABILE e VOLONTARIO nelle organizzazioni con slug da produzione (org-a, org-b, org-c), se esistono. Le email sono prevedibili (<ruolo>.<prefisso>@demo.example, stesso schema per i volontari) e l'upsert ha update vuoto: non sovrascrive account esistenti.	
FILE	src/middleware.ts, src/app/api/internal/demo-seed/route.ts, src/app/api/internal/demo-seed/route.ts, src/app/api/internal/demo-seed/route.ts	
ATTESO / OSSERVATO	Atteso: Endpoint di seed non esposto in produzione, o protetto da ruolo/token e disattivato per ambiente Osservato: Raggiungibile senza autenticazione; crea utenti con credenziale nota (non riportata)	
IMPATTO	Reale: Nessun test eseguito: l'effetto dipende dall'esistenza delle organizzazioni indicate Potenziale: Creazione di account RESPONSABILE e VOLONTARIO con password nota e email prevedibili in organizzazioni reali, con accesso ai loro dati; sede e mezzi demo aggiunti al database Condizioni: Le tre organizzazioni devono esistere nel database; non sovrascrive account già presenti (update vuoto)	
PERCHÉ QUESTA SEVERITÀ	Percorso senza autenticazione verso la creazione di account con password nota; abbassabile se l'endpoint non è presente in produzione o le organizzazioni non esistono.	
CORREZIONE	Rimuovere l'endpoint dalla build di produzione e dall'elenco pubblico; se serve, eseguire il seed solo da script CLI	
SUBITO	Bloccare /api/internal/ dal reverse proxy; verificare se esistono account demo in produzione e cambiarne le password	
RETEST	Verificare su staging con dati finti che la richiesta senza sessione riceva 401/404 e che nessun utente venga creato.	
LIMITI	Non eseguito. Non verificato se la build di produzione contenga la route né se le organizzazioni esistano. Esempio ricavato da un collaudo reale e anonimizzato: nomi, organizzazioni e identificatori sono stati sostituiti.	

APP-005	Next.js 16.1.7 e Auth.js beta con advisory noti, inclusi bypass del middleware su cui poggia l'autenticazione	ALTA
STATO E CONFIDENZA	confermato da codice o configurazione · confidenza media	
RIFERIMENTI	CWE-1395, CWE-863 · ASVS v5.0.0 (dipendenze); NIST SP 800-53 SI-2, RA-5; ACN PR.PS-02 (software mantenuto)	
PROVA	npm audit sul solo lockfile (invia nomi e versioni dei pacchetti, nessun codice): next 16.1.7 ricade nell'intervallo vulnerabile 9.3.4-canary.0 – 16.4.0 con advisory fra cui tre di bypass del middleware/proxy (GHSA-26hh-7cqf-hhc6, GHSA-492v-c6pp-mqqv, GHSA-267c-6grr-h53f), SSRF, DoS e XSS con nonce CSP. Auth.js (@auth/core, tramite next-auth 5.0.0-beta.30): omografia nella normalizzazione email (critical, GHSA-7rqj-j65f-68wh) e getToken con eccezione non gestita. Il totale in produzione è 39 (4 critical, 20 high). L'autenticazione dell'applicazione è centralizzata nel middleware, per cui i bypass sono pertinenti.	
FILE	package.json, package-lock.json, src/middleware.ts	
ATTESO / OSSERVATO	Atteso: Versioni senza advisory noti, o advisory valutati come non raggiungibili e documentati Osservato: Versioni in intervallo vulnerabile; raggiungibilità non valutata caso per caso	
IMPATTO	Reale: Non dimostrato Potenziale: Aggiramento del middleware (quindi dei controlli di sessione e ruolo sulle route), DoS, SSRF; i tre advisory critical su RCE riguardano Image Optimization con AVIF/SVG, `use cache` e host Windows: nel codice non c'è `use cache` e remotePatterns è vuoto, ma l'ottimizzazione immagini e il sistema di hosting non sono stati valutati Condizioni: Raggiungibilità per ciascun advisory non verificata; alcuni richiedono configurazioni specifiche (i18n Pages Router, Turbopack, Windows)	
PERCHÉ QUESTA SEVERITÀ	Il bypass del middleware vale quanto l'autenticazione centralizzata; severità alta in attesa della verifica di raggiungibilità, che può abbassarla.	
CORREZIONE	Aggiornare Next.js alla prima versione fuori dall'intervallo (verificare sulle pagine degli advisory), Auth.js alla versione corretta, nodemailer; rieseguire npm audit; documentare ciò che resta	
SUBITO	Aggiungere controlli di sessione e ruolo anche nei gestori delle route, non solo nel middleware	
RETEST	npm audit --omit=dev dopo l'aggiornamento; test di regressione delle route protette con e senza sessione.	
LIMITI	Raggiungibilità non valutata; npm audit usa un database online al momento dell'esecuzione. Altri advisory high (nodemailer, dompurify, sharp, lodash...) non analizzati uno a uno. Esempio ricavato da un collaudo reale e anonimizzato: nomi, organizzazioni e identificatori sono stati sostituiti.	

APP-001	File di configurazione staging con valori reali dichiarati, tracciato in Git	MEDIA
STATO E CONFIDENZA	confermato da codice o configurazione · confidenza media	
RIFERIMENTI	CWE-798, CWE-540 · ASVS v5.0.0 (gestione dei segreti); NIST SP 800-53 SC-12, IA-5	
PROVA	Il file, nonostante il suffisso .example, apre con il commento che contiene i valori reali per staging e che non va committato. Cinque chiavi sensibili (password PostgreSQL, password Redis, NEXTAUTH_SECRET, CRON_SECRET, chiave privata VAPID) hanno valori con lunghezza ed entropia tipiche di segreti veri, non segnaposto. Valori non riportati. Le regole .gitignore lo riammettono esplicitamente al tracciamento.	
FILE	.env.staging.example, .gitignore	
ATTESO / OSSERVATO	Atteso: Nel repository solo segnaposto; i valori reali fuori da Git (variabili d'ambiente o secret manager) Osservato: Valori dall'aspetto reale in un file tracciato; l'autenticità non è stata provata (nessuna prova fuori perimetro)	
IMPATTO	Reale: Esposizione dei segreti a chi legge il repository Potenziale: Se coincidono con quelli in uso: falsificazione di sessioni, accesso a database/cache di staging, invio di notifiche push; riuso su altri ambienti Condizioni: Repository privato; ambiente staging; autenticità e raggiungibilità non verificate	
PERCHÉ QUESTA SEVERITÀ	Segreti plausibilmente reali in Git, ma repository privato e ambiente non produttivo. Sale ad alta se riusati in produzione o se il repository diventa pubblico.	
CORREZIONE	Ruotare i cinque segreti, sostituire i valori con segnaposto, togliere dal tracciamento, valutare la pulizia della cronologia Git	
SUBITO	Ruotare subito i segreti; escludere il file da .gitignore	
RETEST	Verificare che il file contenga solo segnaposto, che la cronologia non contenga i vecchi valori e che i segreti in uso siano diversi.	
LIMITI	Clone shallow: cronologia non esaminata. Non provato se i valori siano in uso. Valori mai riportati nel report. Esempio ricavato da un collaudo reale e anonimizzato: nomi, organizzazioni e identificatori sono stati sostituiti.	

APP-003	Route di debug e seed raggiungibili da qualsiasi utente autenticato, con effetti di stato via GET	MEDIA
STATO E CONFIDENZA	confermato da codice o configurazione · confidenza media	
RIFERIMENTI	CWE-862, CWE-352 · ASVS v5.0.0 (controllo di accesso a livello di funzione); WSTG-ATHZ-02; NIST SP 800-53 AC-3, AC-6	
PROVA	Il middleware richiede solo una sessione per questi percorsi. I gestori GET non controllano il ruolo: debug/fix-modules modifica moduli di un'organizzazione individuata da un indirizzo email fisso scritto nel codice; internal/seed-demo e seed-sector fanno upsert di organizzazioni, sedi e utenti (seed-demo crea utenti ADMIN con un hash di password nota). Altre route di debug (verify-timbrature, init-calendars) richiedono ADMIN: l'assenza del controllo qui è una svista, non una scelta.	
FILE	src/app/api/debug/fix-modules/route.ts, src/app/api/internal/seed-demo/route.ts, src/app/api/internal/seed-demo/route.ts, src/app/api/internal/seed-sector/route.ts, src/middleware.ts, src/app/api/debug/verify-timbrature/route.ts	
ATTESO / OSSERVATO	Atteso: Funzioni amministrative o di debug riservate a ruolo adeguato, non invocabili con GET e assenti in produzione Osservato: Nessun controllo di ruolo; mutazioni tramite GET (attivabili anche da link o immagine su pagina terza per un utente collegato)	
IMPATTO	Reale: Nessun test eseguito Potenziale: Modifica della configurazione di un'organizzazione; creazione di organizzazioni demo e di account ADMIN con password nota; effetti attivabili via CSRF su GET se i cookie di sessione sono inviati cross-site (SameSite da verificare) Condizioni: Serve una sessione valida; effetti su organizzazioni demo/indirizzo fisso	
PERCHÉ QUESTA SEVERITÀ	Operazioni amministrative senza controllo di ruolo, ma con perimetro di effetto limitato e sessione obbligatoria.	
CORREZIONE	Eliminare le route dalla build di produzione o imporre ruolo ADMIN/SystemAdmin e metodo POST con protezione CSRF	
SUBITO	Bloccare /api/debug e /api/internal dal reverse proxy	
RETEST	Con un utente VOLONTARIO sintetico su staging: GET sulle tre route deve dare 403/404 e non modificare dati.	
LIMITI	Non eseguito. Il resto delle route di debug e il comportamento dei cookie SameSite non sono stati esaminati. Esempio ricavato da un collaudo reale e anonimizzato: nomi, organizzazioni e identificatori sono stati sostituiti.	

APP-004	Accettazione preventivo senza controllo di proprietà: risposta con password temporanea e dati del contatto	MEDIA
STATO E CONFIDENZA	confermato da codice o configurazione · confidenza media	
RIFERIMENTI	CWE-639, CWE-200, CWE-522 · ASVS v5.0.0 (controllo di accesso, gestione credenziali); WSTG-ATHZ-04; NIST SP 800-53 AC-3, IA-5	
PROVA	Le route /api/quotes/[id] e /api/quotes/[id]/accept non verificano sessione, ruolo o appartenenza; il middleware non le elenca fra i percorsi pubblici, quindi basta una sessione qualsiasi (il flusso, descritto come pubblico, è anche incoerente col middleware). GET restituisce preventivo con lead (nome, email, telefono, messaggio) e organizzazione. POST crea un'organizzazione e un utente ADMIN e restituisce nella risposta l'intero risultato, che include la password temporanea in chiaro.	
FILE	src/app/api/quotes/[id]/route.ts, src/app/api/quotes/[id]/accept/route.ts, src/app/api/quotes/[id]/accept/route.ts, src/app/api/quotes/[id]/accept/route.ts	
ATTESO / OSSERVATO	Atteso: Solo il destinatario del preventivo (token dedicato) può leggerlo/accettarlo; password mai restituita nella risposta, solo via email Osservato: Nessun controllo di proprietà; password temporanea nel corpo della risposta	
IMPATTO	Reale: Nessun test eseguito Potenziale: Lettura di dati personali di contatti commerciali; presa di controllo dell'account amministratore creato dall'accettazione, da parte di chi non è il destinatario Condizioni: Servono sessione e identificativo (cuid, non enumerabile ma non segreto); preventivo non scaduto né già accettato	
PERCHÉ QUESTA SEVERITÀ	Possibile appropriazione dell'account ADMIN generato, ma richiede identificativo e sessione; sale ad alta se gli identificativi sono ricavabili da altre route.	
CORREZIONE	Link con token monouso e scadenza; togliere la password dalla risposta; ridurre i campi restituiti	
SUBITO	Disabilitare le route finché non protette	
RETEST	Con due organizzazioni sintetiche: la seconda non deve leggere né accettare il preventivo della prima; la risposta non deve contenere password.	
LIMITI	Non eseguito. Non verificato come gli identificativi dei preventivi vengano diffusi (email, UI, altre API). Esempio ricavato da un collaudo reale e anonimizzato: nomi, organizzazioni e identificatori sono stati sostituiti.	

4 Audit documentale

Confronto tra ciò che i documenti affermano e ciò che risulta da codice e configurazione, più completezza e aggiornamento dei documenti.

Esito: 3 incoerente, 2 obsoleto, 1 duplicato, 1 non verificabile, 1 mancante su 8 voci esaminate.

ID	DOCUMENTO	STATO	RILIEVO E AZIONE
D01	File di istruzioni del progetto (non datato)	INCOERENTE	Dichiarazione di sicurezza non sostenuta dal codice. Azione: Correggere il documento o il codice
D02	File di istruzioni del progetto (non datato)	INCOERENTE	Elenco incompleto: la route non è documentata. Azione: Allineare l'elenco al middleware
D03	Documento «implementazione MFA completa» (02/2026)	INCOERENTE	Il titolo afferma ciò che il testo smentisce. Azione: Rinominare o chiudere il lavoro
D04	Tre documenti sullo stato di conformità (02-03/2026)	DUPLICATO	Nessuna indica metodo o autore. Azione: Tenerne una sola, datata, con metodo e limiti
D05	Rapporto di test interno (03/2026)	NON VERIFICABILE	Autore, metodo e perimetro non dichiarati. Azione: Dichiarare chi, come e cosa è stato testato
D06	Piano di continuità operativa (01/2025)	OBSOLETO	Piano non riesaminato. Azione: Riesaminare e registrare un test di ripristino
D07	Radice del repository	OBSOLETO	Rumore che nasconde i documenti validi. Azione: Archiviare o eliminare
D08	—	MANCANTE	Utile per l'inventario e la gestione delle vulnerabilità. Azione: Generare un SBOM a ogni rilascio

5 Copertura e limiti

La copertura riguarda solo ciò che è stato inventariato: non prova l'assenza di problemi non censiti.

4 su 7
Voci inventariate esaminate per intero

2 su 7
Voci esaminate in parte

0 su 4
Endpoint con almeno un test eseguito

- Route API: 309 nel progetto, circa 14 lette; oltre 280 non lette.

Non verificato

- Cronologia Git, build di produzione, firewall e hosting.
- Raggiungibilità dei singoli advisory.
- Matrice dei controlli ASVS/NIST/ACN: non compilata in modalità rapido.

Domande aperte per il proprietario

- Le route di debug e di seed sono nella build di produzione?
- Quale documento di conformità è quello vigente?

6 Matrici di copertura

Il dettaglio da cui derivano i conteggi: cosa è stato esaminato, quali endpoint sono censiti e con quale test.

Inventario e copertura

AREA O PERCORSO	VERIFICA	ESAMINATO	NOTE
src/middleware.ts	lettura integrale	SI	autenticazione, CSP, ruoli
src/app/api (309 route)	ricerca euristica + lettura mirata	PARZIALE	modalità rapido. circa 14 gestori letti; oltre 280 non letti
.env* e secrets/	controllo valori mascherati	SI	solo la forma dei valori
Dockerfile e file Compose	lettura mirata	SI	porte, utente, immagine base
package.json e lockfile	npm audit su lockfile	SI	raggiungibilità non valutata
Documentazione (65 file in docs/ e 37 nella radice)	lettura mirata	PARZIALE	modalità rapido. letti per intero solo i documenti citati
Pagine, componenti, worker, test	non letto	NO	modalità rapido

Endpoint censiti

ENDPOINT	METODO	IDENTITÀ E RUOLO	AZIONE	TEST	FINDING
/api/internal/demo-seed	POST	anonimo / nessuno	creazione (utenti demo)	NO	APP-002
/api/debug/fix-modules	GET	utente / qualsiasi	modifica (organizzazione)	NO	APP-003
/api/quotes/{id}	GET	utente / qualsiasi	lettura (preventivo)	NO	APP-004
/api/quotes/{id}/accept	POST	utente / qualsiasi	accettazione (preventivo)	NO	APP-004

«Test: no» significa che l'endpoint è stato censito dal codice ma non provato. Gli stati dei finding collegati dicono cosa è dimostrato.

7 Piano di intervento proposto

Subito

ID	INTERVENTO	RESPONSABILE PROPOSTO
APP-002	Rimuovere l'endpoint dalla build di produzione e dall'elenco pubblico; se serve, eseguire il seed solo da script CLI	Proprietario / sviluppatore
APP-005	Aggiornare Next.js alla prima versione fuori dall'intervallo (verificare sulle pagine degli advisory), Auth.js alla versione corretta, nodemailer; rieseguire npm audit; documentare ciò che resta	Sviluppatore

Prossime settimane

ID	INTERVENTO	RESPONSABILE PROPOSTO
APP-001	Ruotare i cinque segreti, sostituire i valori con segnaposto, togliere dal tracciamento, valutare la pulizia della cronologia Git	Proprietario del progetto
APP-003	Eliminare le route dalla build di produzione o imporre ruolo ADMIN/SystemAdmin e metodo POST con protezione CSRF	Sviluppatore
APP-004	Link con token monouso e scadenza; togliere la password dalla risposta; ridurre i campi restituiti	Sviluppatore

I tempi dipendono da impatto e obblighi del titolare; non sono scadenze di legge. Dopo ogni correzione va eseguito il retest indicato nel finding.

METODO E AVVERTENZE

Valutazione eseguita con le skill appsec-sentinel e gdpr-sentinel (Apache-2.0). Ogni finding ha uno stato che dice cosa è stato dimostrato. Non è un penetration test completo, non certifica sicurezza o conformità e non sostituisce il parere di DPO e legale. Segreti e dati personali non sono riportati. Le fonti normative e gli standard vanno riverificati prima di citarli.